

Rapport d'Audit de Sécurité

Analyse OpenSSF & Dépendances - Projets Nextcloud, Keycloak et Suricata

1. Tableau d'Audit (Scorecard Comparatif)

Ce tableau présente une évaluation basée sur les métriques OpenSSF issues des scans Scorecard de votre répertoire d'audit pour les projets Nextcloud, Keycloak et Suricata.

Critère OpenSSF	Nextcloud Server	Keycloak	Suricata
Score Global	6.4 / 10	8.7 / 10	8.5 / 10
Maintenu (Activité)	10 / 10	10 / 10	10 / 10
Code Review	8 / 10	10 / 10	8 / 10
CI/CD Tests	10 / 10	10 / 10	10 / 10
Branch Protection	4 / 10	8 / 10	8 / 10
Vulnérabilités Non Corrigées	0 / 10	N/A	N/A

2. Rapport de Synthèse des Risques

L'analyse approfondie des dépendances (via Trivy / Dependency-Check) du composant `build/frontend-legacy` de **Nextcloud** révèle une posture modérée. Aucune vulnérabilité critique ou haute n'est présente sur ce périmètre.

Criticité Globale : MODÉRÉE. Les risques identifiés (3 MEDIUM, 2 LOW) sont concentrés sur l'écosystème NPM (Node.js). Ils concernent des vecteurs de déni de service (DoS) et des entropies faibles sur des bibliothèques vieillissantes. Bien que la surface d'attaque en production soit limitée (composants build/legacy), la chaîne d'approvisionnement (Supply Chain) nécessite un durcissement, d'autant plus que le Scorecard global (6.4/10) souligne la présence de vulnérabilités non corrigées (score de 0/10 sur ce critère) et des axes d'amélioration sur la protection des branches (4/10).

3. Liste des CVE Identifiées (Top 3 les plus critiques sur Nextcloud)

L'analyse du fichier `package-lock.json` a mis en évidence les vulnérabilités suivantes :

CVE ID	Composant	Sévérité	Description du Risque	Statut / Correctif
CVE-2026-41305	<code>postcss</code> (v8.5.6 & v8.5.8)	MEDIUM	Vulnérabilité dans le traitement des CSS pouvant entraîner une consommation excessive des ressources et un déni de service (DoS).	Corrigé dans 8.5.10
CVE-2026-33750	<code>brace-expansion</code> (v2.0.2)	MEDIUM	Problème lié à l'expansion des accolades entraînant potentiellement un épuisement de la mémoire.	Corrigé dans 5.0.5
CVE-2026-41907	<code>uuid</code> (v12.0.0)	MEDIUM	Faiblesse dans la génération de nombres aléatoires réduisant l'entropie des identifiants générés.	Corrigé dans 12.0.1

Note : Deux vulnérabilités additionnelles de sévérité LOW ont été détectées sur `elliptic` (CVE-2025-14505) et `vue` (CVE-2024-9506).

4. Recommandations Documentées

1. Application des Patches (Action Immédiate)

Les vulnérabilités découvertes disposent de correctifs. Pour le périmètre Nextcloud (frontend-legacy) :

- Exécuter `npm audit fix` ou forcer manuellement la mise à jour des packages (ex: `npm install postcss@8.5.10`).

2. Renforcement des Politiques GitHub (Moyen Terme)

Conformément au rapport Scorecard (score de 4/10 sur Branch-Protection) :

- Activer une politique stricte de protection des branches sur le dépôt Nextcloud : interdire les push directs sur les branches principales et de release, et exiger des revues de code validées (approvals).

3. Gouvernance Supply Chain (Long Terme)

Pour l'ensemble des projets audités (Nextcloud, Keycloak, Suricata) :

- Systématiser la génération et la signature des **SBOM** via Trivy ou Syft dans la CI/CD.
- Mettre en place un outil d'alerte automatisé pour la mise à jour des dépendances (Dependabot, Renovate).

5. Extrait du SBOM (CycloneDX) - Nextcloud

Cet extrait illustre la nomenclature logicielle (Software Bill of Materials) générée suite à l'analyse :

```
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.5",
  "metadata": {
    "timestamp": "2026-06-02T14:09:55Z",
    "tools": [{"vendor": "aquasecurity", "name": "trivy"}],
    "component": {"type": "application", "name": "nextcloud-frontend-legacy"}
  },
  "components": [
    {
      "type": "library",
      "name": "postcss",
      "version": "8.5.6",
      "purl": "pkg:npm/postcss@8.5.6",
      "properties": [
        { "name": "aquasecurity:trivy:Vulnerability", "value": "CVE-2026-41305" }
      ]
    }
  ]
}
```